Matriz de criterios de seguridad — Palco

Desarrollo de Aplicaciones II · UADE · Clase 11 · Taller de seguridad de aplicaciones

Grupo / dominio	Grupo N · Palco (venta de entradas nominativas con reventa oficial, tope +10%)
Integrantes	Santiago Loto, Sebastian Deya, Julian Zuchowicki, Valentina Frisoli, Joaquin Molina
Tablero (Notion, en lugar de Jira)	Tablero de Tareas D Apps 2: https://app.notion.com/p/3caf71443ad4807d8749c3543f74c075 · 10 tarjetas con etiqueta "seguridad" e ID SEC-xx. El equipo usa Notion; no tiene Jira.
Alcance	Backend Jakarta EE (8 servicios) y frontend web responsive. No hay app móvil, así que en lugar de los 2 criterios mobile se incluyen 2 de datos sensibles.
Estado de la evidencia	Los veredictos salen de leer el código del repo y de la corrida de tests del backend del 16/10 a las 08:25 (mvn test: 313 tests, 0 fallas, BUILD SUCCESS). Solo los criterios marcados "test en verde" tienen un test que los cubre directamente; el resto queda como CUMPLE EN CÓDIGO hasta correr su Postman o su prueba.

1. Resumen

ID	Área	Criterio	Referencia	Veredicto
SEC-W01	Web/API	Una entrada ajena no se puede consultar (BOLA)	OWASP API1:2023 (BOLA)	**CUMPLE · test en verde**
SEC-W02	Web/API	El rol decide quién usa cada operación	OWASP API5:2023 (BFLA)	**CUMPLE EN CÓDIGO**
SEC-W03	Web/API	El login no revela si el email existe	A07:2025	**CUMPLE EN CÓDIGO**
SEC-W04	Web/API	Bloqueo tras 5 logins fallidos en 15 minutos	A07:2025	**NO CUMPLE**
SEC-W05	Web/API	Tokens alterados, sin firma o de larga vida se rechazan	A07:2025	**PARCIAL**
SEC-W06	Web/API	Entrada inválida: 400 limpio y sin persistir	A05:2025	**CUMPLE · test en verde**
SEC-I01	Integración	SOAP seguro y con estado controlado ante timeout	A02:2025	**NO VERIFICABLE**
SEC-I02	Integración	Permisos por destino en el broker	A01:2025	**NO CUMPLE**
SEC-D01	Datos sensibles	Los logs no contienen DNI	Ley 25.326	**CUMPLE EN CÓDIGO**
SEC-D02	Datos sensibles	Contraseñas con hash y nunca en respuestas	A04:2025	**CUMPLE EN CÓDIGO**

Sobre 10 criterios: 2 cumplen con test en verde, 4 sin hallazgos en el código, 1 parcial, 2 no cumplen y 1 no se pueden verificar todavía.

Distribución pedida: 6 web/API, 2 de integración (SOAP y mensajería) y 2 de datos sensibles (en lugar de mobile).

2. Matriz de criterios (Dado / Cuando / Entonces)

SEC-W01 · Una entrada ajena no se puede consultar (BOLA)

Referencia	OWASP API1:2023 (BOLA) · A01:2025 · ASVS 5.0 Autorización
DADO	un comprador B autenticado y una entrada que pertenece al comprador A
CUANDO	B envía GET /api/v1/entradas/{id} con su propio token
ENTONCES	la API responde 404 application/problem+json, sin código QR, titular ni estado de la entrada, igual que si la entrada no existiera
Evidencia	Postman SEC-W01 y SEC-W01b en verde + test de ComprasEnCurso con entrada de otro comprador
Cómo se verifica	Postman (carpeta 4 Seguridad) con tokenA / tokenB

Análisis del código	ComprasEnCurso.java:189-193 filtra la entrada por el compradorId del token y responde NoEncontrado, lo mismo que si no existiera. Igual en ventas (delComprador, :322-326). El recurso saca el usuario del token (Sesion.usuarioId), no de un parámetro. Test ejecutado el 16/10 (mvn test, 313 tests, 0 fallas): ComprasEnCursoTest.unaVentaAjenaRespondeLoMismoQueUnaQueNoExiste y laEntradaSoloLaVeQuienLaCompro.
Veredicto	**CUMPLE · test en verde**
Acción	Adjuntar la salida del mvn test. Opcional: correr también el Postman SEC-W01 contra el servidor.
Resultado del test	☐ Verde ☐ Rojo Captura: (adjuntar)
Responsable (Notion)	Sebastian Deya

SEC-W02 · El rol decide quién usa cada operación

Referencia	OWASP API5:2023 (BFLA) · A01:2025 · ASVS 5.0 Autorización
DADO	un usuario con rol user y otro request sin token
CUANDO	el primero hace POST /api/eventos (solo organizer) y el segundo GET /api/v1/ventas
ENTONCES	el primero recibe 403 y el segundo 401 con la cabecera WWW-Authenticate: Bearer, ambos en problem+json
Evidencia	Postman SEC-W02 y SEC-W02b en verde
Cómo se verifica	Postman (carpeta 4 Seguridad)
Análisis del código	EventosResource.java:62 declara @RolesAllowed("organizer") y todas las operaciones de VentasResource son @RolesAllowed("user"). ManejadoresDeErrores.Http (:171) convierte el 403 sin principal en 401 y noAutenticado agrega WWW-Authenticate (:69).
Veredicto	**CUMPLE EN CÓDIGO**
Acción	Ejecutar el Postman. Confirmar que ningún recurso nuevo quede sin anotación (un método sin anotación queda abierto).
Resultado del test	☐ Verde ☐ Rojo Captura: (adjuntar)
Responsable (Notion)	Valentina Frisoli

SEC-W03 · El login no revela si el email existe

Referencia	A07:2025 · ASVS 5.0 Autenticación
DADO	un email que no está registrado y otro registrado con clave incorrecta
CUANDO	cada uno hace POST /api/usuarios/login
ENTONCES	ambos reciben 401 con el mismo detail ("Revisá el email y la contraseña.") y tiempos de respuesta similares
Evidencia	Postman SEC-W03a y W03b en verde; dos tiempos medidos
Cómo se verifica	Postman + comparación de tiempos de respuesta
Análisis del código	ServicioDeUsuarios.java:170-175: calcula el hash contra HASH_FALSO (:67) cuando el email no existe para igualar tiempos, y lanza siempre ERROR_LOGIN (:62). Los tiempos no se midieron.
Veredicto	**CUMPLE EN CÓDIGO**
Acción	Ejecutar el Postman y comparar el tiempo de ambos requests.
Resultado del test	☐ Verde ☐ Rojo Captura: (adjuntar)
Responsable (Notion)	Santiago Loto

SEC-W04 · Bloqueo tras 5 logins fallidos en 15 minutos

Referencia	A07:2025 · ASVS 5.0 Autenticación (anti-automatización)
DADO	un usuario registrado con 5 intentos fallidos de login en los últimos 15 minutos
CUANDO	hace un sexto intento POST /api/usuarios/login (aun con la clave correcta)
ENTONCES	la API responde 429 con Retry-After, problem+json, y no valida la clave durante 15 minutos
Evidencia	Postman SEC-W04 (6.° intento) devolviendo 429
Cómo se verifica	Postman con pre-request que manda 5 intentos fallidos

Análisis del código	Solo existe límite de intentos para el código de verificación de email (MAX_INTENTOS_CODIGO = 5, ServicioDeUsuarios.java:60). iniciarSesion (:170-178) no cuenta intentos fallidos: se puede probar claves sin límite.
Veredicto	**NO CUMPLE**
Acción	Agregar contador por email (y por IP) con ventana de 15 min y 429 Problem Details. Prioridad alta.
Resultado del test	☐ Verde ☐ Rojo Captura: (adjuntar)
Responsable (Notion)	Santiago Loto

SEC-W05 · Tokens alterados, sin firma o de larga vida se rechazan

Referencia	A07:2025 · A04:2025 · ASVS 5.0 Gestión de sesión / tokens
DADO	un token con la firma alterada, otro con alg "none" y un token recién emitido
CUANDO	se usan en GET /api/usuarios/yo y se decodifica el recién emitido
ENTONCES	los dos primeros reciben 401, y el token emitido tiene exp - iat ≤ 900 s
Evidencia	Postman SEC-W05a y W05b en verde; W05c rojo hoy
Cómo se verifica	Postman + TokensTest.unTokenModificadoNoVerifica
Análisis del código	Firma: los tokens son RS256 y cada servicio los verifica con el JWKS de Usuarios y el emisor "palco" (microprofile-config.properties: mp.jwt.verify.*); TokensTest ya prueba un token modificado. Vigencia: DURACION_SESION = 8 horas (ServicioDeUsuarios.java:55) y no hay refresh token ni revocación al cerrar sesión. Además, el 401 por token inválido lo emite el servidor antes de la aplicación: sale sin Problem Details ni cabeceras CORS (el navegador lo ve como error de CORS), y con "Authorization: Bearer " vacío Ventas responde 401 en text/html (visto el 14/10).
Veredicto	**PARCIAL**
Acción	Bajar a 15-30 min con refresh token revocable en logout, o dejar por escrito por qué se acepta 8 h en el TP. Hacer que el 401 del servidor salga en problem+json y con CORS.
Resultado del test	☐ Verde ☐ Rojo Captura: (adjuntar)
Responsable (Notion)	Joaquin Molina

SEC-W06 · Entrada inválida: 400 limpio y sin persistir

Referencia	A05:2025 · A10:2025 · ASVS 5.0 Validación · RFC 9457
DADO	un comprador autenticado
CUANDO	hace POST /api/v1/ventas sin la cabecera Idempotency-Key
ENTONCES	la API responde 400 problem+json que nombra la cabecera, sin stack trace ni datos internos, y no crea ninguna venta ni reserva
Evidencia	Postman SEC-W06 en verde + conteo de ventas sin cambios
Cómo se verifica	Postman + VentasResourceTest.sinClaveOConUnaQueNoEsUnUuidElPedidoEsInvalido
Análisis del código	VentasResource.claveValida lanza DatosInvalidos antes de llamar a ComprasEnCurso, así que no se llega a reservar cupo. Los errores salen como Problema (RFC 9457) desde ManejadoresDeErrores; el 500 es genérico y loguea el detalle (:218). Falta un id de correlación en el 500. VentasResourceTest.sinClaveOConUnaQueNoEsUnUuidElPedidoEsInvalido pasó en la corrida del 16/10 (313 tests, 0 fallas).
Veredicto	**CUMPLE · test en verde**
Acción	Adjuntar la salida del mvn test y correr el Postman SEC-W06. Mejora: sumar id de correlación al 500.
Resultado del test	☐ Verde ☐ Rojo Captura: (adjuntar)
Responsable (Notion)	Sebastian Deya

SEC-I01 · SOAP seguro y con estado controlado ante timeout

Referencia	A02:2025 · A05:2025 (XXE) · A10:2025 · ASVS 5.0 XML / Servicios web
DADO	el cliente SOAP de Facturación hacia ARCA/AFIP
CUANDO	el parser recibe un XML con DTD/entidad externa, o ARCA no responde en 5 s

ENTONCES	la entidad externa no se resuelve (error controlado) y, ante el timeout, la venta queda CONFIRMADA con factura PENDIENTE y el reintento va a cola.reintento-facturacion, sin hilos colgados
Evidencia	test con XML malicioso + test con servicio SOAP simulado que demora 6 s
Cómo se verifica	Test de integración (JUnit) con servidor SOAP simulado
Análisis del código	FacturacionApplication.java es hoy una clase vacía de 13 líneas: todavía no hay contrato SOAP ni cliente. El diseño está en la actividad de la Clase 9 y el plan de Facturación (commit "plan de Facturación SOAP (C1)").
Veredicto	**NO VERIFICABLE**
Acción	Reevaluar cuando Facturación esté implementada (Entrega 3). Al implementarla, deshabilitar DTD y entidades externas desde el principio.
Resultado del test	☐ Verde ☐ Rojo Captura: (adjuntar)
Responsable (Notion)	Joaquin Molina

SEC-I02 · Permisos por destino en el broker

Referencia	A01:2025 · A06:2025 · Mínimo privilegio · ASVS 5.0 Arquitectura
DADO	el broker JMS con cola.emision-entradas y topico.compra-confirmada, y la identidad del consumidor de Notificaciones
CUANDO	ese consumidor intenta publicar en cola.emision-entradas
ENTONCES	el broker rechaza con error de autorización y el intento queda registrado
Evidencia	test JMS que muestra la excepción de seguridad + configuración de usuarios/roles por destino
Cómo se verifica	Test JMS contra el WildFly del equipo + revisión de configurar.cli
Análisis del código	servidor/src/main/wildfly/configurar.cli (:30-38) deja reintentos acotados (max-delivery-attempts=5, 2 s de espera) y DLQ, pero no define usuarios ni permisos por cola o tópico: cualquier servicio puede publicar en cualquier destino. En el servidor armado (standalone.xml) queda la configuración de fábrica: security-setting "#" con rol guest que puede enviar y consumir, y una RemoteConnectionFactory en el listener HTTP (interfaz pública en 127.0.0.1). No verificado si un cliente remoto entra sin credenciales.
Veredicto	**NO CUMPLE**
Acción	Definir un usuario por servicio y security-setting por destino, o registrar el riesgo como aceptado para la entrega. Prioridad media.
Resultado del test	☐ Verde ☐ Rojo Captura: (adjuntar)
Responsable (Notion)	Julian Zuchowicki

SEC-D01 · Los logs no contienen DNI

Referencia	Ley 25.326 · A09:2025 · ASVS 5.0 Registro
DADO	una compra confirmada con titulares nominativos que tienen DNI
CUANDO	Notificaciones procesa PAGO_CONFIRMADO y escribe el aviso en el log
ENTONCES	el log no contiene ningún DNI y el aviso sale en un solo renglón (sin inyección de líneas)
Evidencia	búsqueda del DNI de prueba en standalone.log sin resultados + tests de Notificaciones en verde
Cómo se verifica	Comprar con un DNI de prueba y hacer grep; mvn test en notificaciones
Análisis del código	ServicioDeNotificaciones.textoDelAviso (:37) arma el texto solo con nombre y sector, sin DNI, y lo pasa por Textos.enUnaLinea. LogEnUnSoloRenglonTest y AvisoDeCompraMDBTest cubren el formato. Solo se revisó Notificaciones: faltan los logs de los otros servicios.
Veredicto	**CUMPLE EN CÓDIGO**
Acción	Hacer el grep sobre el log completo tras una compra de prueba.
Resultado del test	☐ Verde ☐ Rojo Captura: (adjuntar)
Responsable (Notion)	Julian Zuchowicki

SEC-D02 · Contraseñas con hash y nunca en respuestas

Referencia	A04:2025 · ASVS 5.0 Credenciales · Ley 25.326
DADO	un usuario registrado

CUANDO	se consulta su registro en la base y se pide GET /api/usuarios/yo
ENTONCES	la base guarda solo un hash con sal (pbkdf2-sha256$iteraciones$sal$hash) y la respuesta no incluye contraseña ni hash
Evidencia	consulta a la tabla de usuarios + Postman SEC-D02 en verde + ContrasenasTest
Cómo se verifica	SELECT sobre la tabla de usuarios, Postman y mvn test en usuarios
Análisis del código	Contrasenas.java:19-20 usa PBKDF2-HMAC-SHA256 con 310.000 iteraciones y sal aleatoria de 16 bytes; UsuarioDto no tiene campos de contraseña. ContrasenasTest verifica la sal y los hashes mal formados. Observación: la guía de OWASP hoy pide más iteraciones para PBKDF2-SHA256 (del orden de 600.000); conviene chequearlo.
Veredicto	**CUMPLE EN CÓDIGO**
Acción	Correr la consulta SQL y el Postman; evaluar subir las iteraciones.
Resultado del test	☐ Verde ☐ Rojo Captura: (adjuntar)
Responsable (Notion)	Valentina Frisoli

3. Verificación con Claude Fable 5.1 (3 criterios)

Se prepararon los prompts de SEC-W01, SEC-W04 y SEC-W05. Se pegan en Fable con solo los archivos indicados (nada de .env ni datos reales). El veredicto que figura abajo como "previo" es el análisis de código de este documento, no la respuesta de Fable: el grupo tiene que correr Fable, ejecutar el test que proponga y reemplazar esta columna por el resultado real.

ID	Archivos que se pasan	Criterio	Veredicto previo	Evidencia previa
SEC-W01	ComprasEnCurso.java, EntradasResource.java	Dado un comprador B autenticado y una entrada del comprador A, cuando B pide GET /api/v1/entradas/{id}, entonces 404 problem+json sin datos de la entrada.	CUMPLE (test en verde)	ComprasEnCursoTest, 2 tests
SEC-W04	ServicioDeUsuarios.java, UsuariosResource.java	Dado un usuario con 5 logins fallidos en 15 min, cuando hace un sexto intento, entonces 429 con Retry-After y la clave no se valida.	NO CUMPLE (previo)	iniciarSesion (:170-178) no cuenta intentos
SEC-W05	Tokens.java, ServicioDeUsuarios.java, microprofile-config.properties	Dado un token alterado, otro alg none y uno recién emitido, entonces los dos primeros dan 401 y exp - iat ≤ 900 s.	PARCIAL (previo)	firma OK; DURACION_SESION = 8 h (:55)

Prompt (un criterio por pedido; reemplazar los datos entre corchetes):

```
Revisá la seguridad de nuestro propio proyecto (Palco, TP académico de UADE).
Criterio [ID]: [Dado ... Cuando ... Entonces ...].
Archivos: [archivos de la tabla].
Respondé CUMPLE / NO CUMPLE / NO VERIFICABLE, con evidencia (archivo:línea),
la corrección sugerida y un test (JUnit + REST Assured o Postman) que lo compruebe.
No inventes líneas que no estén en los archivos que te paso.
```

Después: ejecutar el test propuesto, guardar la captura (verde o rojo) y subirla a la tarjeta del criterio en Notion. Declarar el uso de IA en el Anexo del TP.

Resultado de Fable (a completar por el grupo):

ID	Veredicto de Fable	Test ejecutado	Resultado y captura
SEC-W01			☐ Verde ☐ Rojo
SEC-W04			☐ Verde ☐ Rojo
SEC-W05			☐ Verde ☐ Rojo

4. Hallazgos y plan

- **Alta · SEC-W04.** El login no limita intentos fallidos. Es el hallazgo más claro y es chico de arreglar (contador por email y 429).
- **Alta · SEC-W05.** Los tokens duran 8 horas y no hay refresh ni revocación. O se baja la vigencia o se justifica por escrito.
- **Media · SEC-I02.** El broker no tiene usuarios ni permisos por cola o tópico. Hoy cualquier servicio puede publicar en cualquier destino.

- **Media · secretos.** Si falta PALCO_SECRETO_SERVICIOS, vale el secreto público "palco-desarrollo" (TokenDeServicio.java:57) y con él cualquiera obtiene un token de rol servicio. El servidor de desarrollo corre hoy así (confirmado en el log y en backend/.env). Para la demo, definir la variable.
- **Media · 401 del servidor.** Un token inválido recibe 401 antes de llegar a la aplicación: sin Problem Details ni CORS, y en text/html si el Bearer viene vacío.
- **Baja · errores.** El 500 es genérico pero sin id de correlación; falta agregarlo para poder buscar el error en el log.
- **Baja · cabeceras.** No se encontraron en el código las cabeceras HSTS ni X-Content-Type-Options. Puede resolverlas el proxy en producción; hay que decir dónde.
- **Bien resuelto.** Autorización por dueño con 404 (BOLA), roles declarativos, errores en Problem Details sin información interna, CORS con orígenes explícitos, hash con sal y logs sin DNI.
- **Pendiente de implementar.** SEC-I01 (SOAP) se vuelve verificable cuando Facturación tenga código.

5. Cómo se ejecuta y se carga

- **Postman:** importar docs/api/palco-api.postman_collection.json, correr la carpeta "4 Seguridad" con dos usuarios verificados (variables tokenA, tokenB, entradaIdA, ventaIdA, emailA, passwordA).
- **Notion:** las 10 tarjetas ya están en el Tablero de Tareas D Apps 2 (etiqueta seguridad, responsable, entrega Parcial N°2, fecha 19/10). En cada una se tildan los checks y se adjunta la captura del test.
- **Entrega:** Clase11_Grupo<N>_Palco_Seguridad.pdf al canal del grupo en Teams, con esta matriz, los veredictos de Fable, las capturas de los tests y el link al tablero de Notion.